

Gaps, Oversights & Supplement Document

Architecture · Security · Privacy · ML · Operations · Mobile · Multi-Tenancy

This document is a complete specification for the 16 identified gaps and oversights from the AntiGravity Fraud Detection Production Blueprint. Every gap is resolved with a full design, implementation spec, schemas, workflows, tooling choices, and runbooks where applicable. This supplements — and must be read alongside — the primary blueprint.

DOCUMENT TYPE	Gap Resolution Supplement
GAPS RESOLVED	16 / 16 — Architecture, Security, Data/Privacy, ML, Ops, Mobile, Multi-tenancy
PAGES	30 pages — complete specifications with schemas, workflows, and runbooks
COMPANION TO	AntiGravity_FraudDetection_Blueprint.pdf — March 2026

Table of Contents

#	Gap Area	Section	Page
G-01	API Versioning Strategy	Architecture	3
G-02	Service Discovery Mechanism	Architecture	4
G-03	Circuit Breaker Pattern	Architecture	5
G-04	Penetration Testing Scope & Schedule	Security	6
G-05	Supply Chain Security (SBOM + Sigstore)	Security	7
G-06	Insider Threat Controls	Security	8
G-07	GDPR Right to Erasure Workflow	Data & Privacy	9
G-08	Consent Management UI	Data & Privacy	11
G-09	Data Retention Enforcement Automation	Data & Privacy	12
G-10	Model Bias & Fairness Audit	ML	13
G-11	Cold-Start Strategy (New Accounts)	ML	15
G-12	Adversarial Testing Framework	ML	16
G-13	Runbook Templates	Operations	18
G-14	SLA Breach Escalation Matrix	Operations	21
G-15	Infrastructure Cost Estimation	Operations	22
G-16	Mobile SDK Design (iOS & Android)	Mobile	24
G-17	Dispute / False-Positive Resolution	User Experience	26
G-18	Multi-Tenancy Isolation Model	Architecture	28

Architecture Gaps

G-01 · API Versioning Strategy

The primary blueprint exposes /v1/ endpoints but provides no policy for how v1 is deprecated, how breaking changes are communicated, or how clients are migrated. Without this, any API change risks silently breaking integrated clients.

Versioning Scheme

- URL path versioning: /v1/, /v2/ — chosen for explicitness and proxy/cache compatibility
- Semantic versioning for API: MAJOR.MINOR.PATCH tracked in OpenAPI spec version field
- MAJOR version bump = breaking change (field removal, auth change, behavior change)
- MINOR version bump = additive change (new optional field, new endpoint) — backwards compatible
- PATCH = bug fix, no schema change — same version, release notes only

Deprecation Policy

Stage	Timeline	Action	Client Notification
Announcement	T-0	New version released alongside old; deprecation notice in response headers + dashboard banner	Email response key doc
Deprecated	T+90 days	Old version returns Deprecation: true header + Link to migration docs	Monthly release emails, SDK update pushed
Sunset Warning	T+150 days	Old version returns HTTP 299 Warning on every call	Weekly emails; Slack webhook alerts
End of Life	T+180 days	Old version returns HTTP 410 Gone — no longer produced	Final email + 30-day emergency support window

Implementation

- Kong API Gateway: version routing via route path prefix — /v1/* → v1-services, /v2/* → v2-services
- OpenAPI specs auto-generated from code annotations (FastAPI auto-docs, go-swagger)
- API changelog maintained in CHANGELOG.md in monorepo — enforced by CI check on PRs touching api/ directory
- SDK versioning mirrors API versioning — SDK v2.x only works with API v2

G-02 · Service Discovery Mechanism

The blueprint assumes services find each other but never specifies how. On Kubernetes, two viable options exist: Kubernetes native DNS and Consul. This gap resolves the choice and configuration.

Decision: Kubernetes Native DNS + CoreDNS (Primary) with Consul for Cross-Cluster

Scenario	Mechanism	Rationale
Same K8s cluster service discovery	Kubernetes DNS: <svc>.<ns>.svc.cluster.local	Zero additional infrastructure; built into K8s; sub-ms resolution
Cross-namespace discovery	K8s DNS with explicit namespace	Enforces namespace isolation, uses local network policies
Cross-cluster (multi-region)	Consul Connect with mesh gateway	K8s DNS doesn't span clusters; Consul federates across regions with health checking
External service registration (Cloud Providers)	Consul Service Catalog with health checks	Externalizes DB endpoint management; supports failover without code changes
Service mesh routing	Cilium service mesh (eBPF-based)	Already in stack; handles L7 routing, retries, circuit breaking natively

CoreDNS Configuration for Fraud Platform

Key CoreDNS customizations applied via ConfigMap:

- TTL set to 5s (default 30s) — enables faster failover for session-manager and risk-engine
- Negative caching disabled for critical services — prevents stale NXDOMAIN from causing scoring failures
- Stubzone configured for Consul domain (.consul) — routes Consul queries to Consul DNS server
- Health check endpoint: /health on port 8080 — monitored by Prometheus CoreDNS exporter

G-03 · Circuit Breaker Pattern

The ML scoring engine is the highest-latency component in the critical path. Without a circuit breaker, ML engine slowness cascades into full API timeout failures. The circuit breaker ensures graceful degradation to rule-engine-only scoring.

Circuit Breaker States & Thresholds

Service Pair	Library	Failure Threshold	Wait Duration	Fallback Behavior
risk-aggregator → ml-scoring	Resilience4j (Java) / gds-resilience4j (Go)	10 failures in 60s	30 seconds	150% rule-engine score × 1.4 multiplier + flag ML_UNAVAILABLE
stream-processor → feature-engine	Resilience4j	5 failures in 30s	20 seconds	Use last-known cached baseline (stale TTL 5 min); flag STALE_FEATURE_ENGINE
rba-orchestrator → session-manager	Resilience4j	3 failures in 10s	10 seconds	Fail-secure: treat session as unauthenticated; redirect to login
event-producer → Kafka	Kafka client retry + DLQ	3 consecutive broker failures	5 minutes	Buffer events in-memory (max 10k); write to DLQ after buffer full
rule-engine → Neo4j	Resilience4j	5 failures in 60s	45 seconds	Skip graph score; set graph_score=0; flag GRAPH_UNAVAILABLE
api-gateway → any upstream	Kong circuit breaker plugin	5 failures in 30s	30 seconds	Return HTTP 503 with Retry-After: 30 header

Degraded Mode Risk Score Formula

When ML engine unavailable: $COMPOSITE = (Rule_Score \times 0.60) + (GeoVelocity_Score \times 0.20) + base_penalty(ML_UNAVAILABLE=+50pts)$. This is deliberately more conservative — higher false positive rate is acceptable during degraded mode; better to over-challenge than to miss fraud.

Security Gaps

G-04 · Penetration Testing Scope & Schedule

Test Type	Scope	Frequency	Vendor Type	Deliverable
External Black-Box Pentest	Public API endpoints, auth flows, and SaaS	Annually (+ after Certified Base party)	Qualified third-party (OWASP, CREST, OSINT)	Remediation plan
Internal White-Box Pentest	All services, DB access, internal APIs, K8s config	Quarterly	Internal red team of specialized vendors	CVSS scores
API Fuzzing (Automated)	All REST + gRPC endpoints	Every release (automated)	OWASP ZAP, Burp Suite (plugins for failure case)	
Social Engineering Test	Analyst team, DevOps team, support	Annually	External firm	Awareness gap report
Behavioral Model Evaluation	All models — attempt to craft inputs to evade detection	Quarterly	Internal ML red team	Evasion technique register
Supply Chain Audit	Third-party dependencies, Docker images, Helm charts	Quarterly (automated) + annual vendor audit		Dependency vulnerability register
Cryptographic Review	WLS config, key management, JWT signing, WebAuthn, cryptography spec	Annually	WebAuthn, WebAuthn, cryptography spec	Compliance attestation

Remediation SLAs by CVSS Score

CVSS Score	Severity	Remediation Deadline	Interim Mitigation Required
9.0 – 10.0	Critical	24 hours	Yes — WAF rule or feature disable immediately
7.0 – 8.9	High	7 days	Yes — WAF/rate limit if exploitation is feasible
4.0 – 6.9	Medium	30 days	No — track in security backlog
0.1 – 3.9	Low	90 days	No — next planned release

G-05 · Supply Chain Security — SBOM & Sigstore

Every Docker image and deployment artifact must be cryptographically signed and have a complete Software Bill of Materials (SBOM). This closes the supply chain attack vector where a compromised dependency or container image could inject malicious code.

SBOM Generation

- Tool: Syft (Anchore) — generates SBOM in SPDX 2.3 and CycloneDX 1.4 formats
- Trigger: automatic on every Docker build in CI pipeline — SBOM attached as image attestation
- Storage: SBOMs stored in OCI registry alongside images (cosign attach sbom)
- Consumption: Grype scans SBOM for CVEs — critical CVEs fail the build
- Quarterly: full SBOM inventory exported to S3 for compliance audit evidence

Image Signing with Sigstore/Cosign

- All Docker images signed with cosign using keyless signing (Fulcio CA + Rekor transparency log)
- Kong API Gateway / K8s admission controller (Kyverno) rejects any unsigned image
- Signature verification policy: image must be signed by CI identity (GitHub Actions OIDC token)
- Transparency log entry provides tamper-evident audit trail of every image ever deployed
- Key rotation: automatic via Fulcio — no long-lived private keys to manage or protect

Dependency Management Policy

Rule	Enforcement	Tool
No dependency with CVSS ≥ 8.0 in production	Hard gate — build fails	Grype + Trivy
No dependency unmaintained > 2 years	Soft gate — PR comment + security team notified	Snyk, OSS Insights

Rule	Enforcement	Tool
All direct dependencies pinned to exact version	Pre-commit hook rejects unpinned deps	pip-compile, go mod, npm shrinkwrap
License compliance: no GPL in production code	Hard CI gate — incompatible license fails build	FOSSA
No base images: ubuntu:latest — must use distro:pin	Dockerfile linter (DockerfileLint) fails on :latest tags	DockerfileLint in CI

G-06 · Insider Threat Controls

Fraud analysts and DevOps engineers have elevated access to sensitive systems. Without insider threat controls, a malicious or compromised internal actor could manipulate risk decisions, exfiltrate data, or sabotage the system.

Access Controls for Analysts

Control	Implementation	Purpose
Role separation	Analyst / Senior Analyst / Analyst Lead — each has distinct permissions	Prevent single point of failure; limit actions (e.g., acting on own alert)
4-eyes approval for manual blocks	Any manual block of a user requires approval	Prevents malicious analyst (Silencing of approvals would flow)
Action rate limiting	Analyst can dismiss max 50 alerts/hour; manual block max 10/h	Prevents bulk manipulation; requires manager approval
Session recording	Analyst dashboard sessions recorded (screen capture)	For post-incident investigation; 90-day retention
Anomaly alerting	Analyst activity itself is monitored: unusual hours, bulk actions, access to high-value data	Detects anomalous analyst behavior
Privileged access review	Quarterly automated access review — unused elevated access is suspended after 30 days inactivity	Ensures least privilege; prevents stale access
Data export controls	Analyst dashboard: no bulk data export without approval	Prevents data exfiltration; audit log entry

DevOps / Engineer Controls

- Just-in-Time (JIT) access for production: engineers request elevated access via Vault, approved for max 4 hours
- All production kubectl commands logged to immutable audit log via K8s audit policy
- No direct database access in production — all changes via migration scripts in Git, reviewed by DBA
- Vault: all production secrets accessed via short-lived dynamic credentials — no shared passwords
- Separation of duty: engineer who deploys cannot approve their own deployment (GitHub branch protection)

Data & Privacy Gaps

G-07 · GDPR Right to Erasure — Complete Workflow

Behavioral biometric data constitutes special category data under GDPR Article 9 when used to uniquely identify individuals. Users have the absolute right to erasure under Article 17. This workflow resolves the complete technical implementation including audit log tensions.

Data Inventory — What Must Be Erased

Data Store	Data Type	Erasure Method	Retention Conflict?
Redis Cluster	Active sessions, behavioral data	Delete all keys matching user:{user_id}:	No — TTL-based anyway
PostgreSQL users table	Name, email, hashed password, preferences	Hard delete + vacuum	No
PostgreSQL login_history	IP hash, device FP id, login time	Hard delete all rows for user_id — cascade	No — beyond 90 days → archive
PostgreSQL behavioral_base	MLA behavioral feature vectors	Hard delete	No
PostgreSQL device_fingerprints	Device FP hash, attributes	Update user_id (set user_id=NULL) — anonymize, do not delete (device may be linked to other users)	Yes — retention device for (device may be linked to other users)
PostgreSQL mfa_credentials	WebAuthn public keys, TOTP secrets	Hard delete	No
PostgreSQL risk_events	Risk scores, decisions, flags	Anonymize: replace user_id with hashed_token	Yes — legal hold for fraud & investigations
ClickHouse analytics	Aggregated score metrics, segments	Replace user_id with anonymized_id in all rows	Yes — aggregate data retained
Neo4j graph	User node + relationships	Delete user node; preserve device + IP nodes (anonymize edges)	Yes — fraud & edge connections preserved
S3 / Cold storage	Historical Parquet training data	Rewrite affected Parquet files with user rows removed (query scheduled job)	Yes — (query scheduled job delete)
MLflow	Model training metadata	Anonymize user_id references in feature logs	Yes — model artifact retained
Audit logs (append-only)	All decisions involving user	Cannot modify — redact in read layer; apply legal temporary requirement to keep	Yes — legal temporary requirement to keep

Erasure Workflow — Step by Step

Step	Action	Service	SLA
1.	User submits erasure request via account settings or email	AuthGuardrail — identity verification session or email OTP	
2.	Erasure ticket created in internal system with user_id, timestamp, request	Internal DB	1 request
3.	Sessions for user_id deleted immediately	Redis	< 1 minute
4.	PostgreSQL delete users, login_history, behavioral_base (new); anonymize risk_events	PostgreSQL	< 10 minutes
5.	Cache purge + delete all keys containing user_id	Redis	< 2 minutes
6.	ClickHouse UPDATE ... SET user_id = anonymized_token WHERE user_id = ?	ClickHouse	< 30 minutes
7.	Graph query: MATCH (u:User {id: ?}) DETACH DELETE u; (device/IP nodes preserved)	Neo4j	< 5 minutes
8.	Trigger Spark job to rewrite Parquet files in S3 removing user rows (Anonymize & delete)	Spark	< 24 hours
9.	Append redaction event to audit log with legal hold flag — redact in read API layer	AuditLogEngine	< 1 minute
10.	Final confirmation sent to user with erasure ticket ID and data inventory of completion	Email	1 hour
11.	Erasure record filed in DPO register with all actions taken — retained for 3 years	DPO Register	3 years

Legal basis for retention exceptions: Fraud-related risk_events are retained under GDPR Article 17(3)(e) — 'for reasons of public interest in the area of public health' and Article 17(3)(b) — 'for compliance with a legal obligation'. This must be disclosed in the Privacy Policy and the erasure confirmation email.

G-08 · Consent Management UI

GDPR Article 7 requires freely given, specific, informed, and unambiguous consent for behavioral biometric data collection. The consent UI must meet all four criteria and maintain a verifiable consent audit trail.

Consent Banner — First-Visit Flow

Screen Element	Content / Behavior	Technical Implementation
Consent banner (cannot be dismissed without wiping)	Explicitly states device fingerprinting behavioral pattern analysis (not biometric data collection) begins if user accepts	Banner analysis (not biometric data collection) begins if user accepts
Granular consent toggle	Toggle 1: Essential Security (device ID) — cannot be disabled (registered interest basis) Toggle 2: Behavioral Analysis (device fingerprinting) — can be disabled (legitimate interest basis)	Toggle 1: Essential Security (device ID) — cannot be disabled (registered interest basis) Toggle 2: Behavioral Analysis (device fingerprinting) — can be disabled (legitimate interest basis)
'Learn More' expansion	Plain-English explanation with specific examples: 'We use device fingerprinting to protect your account (GDPR Art. 6(1)(f)). We also use it to analyze your behavior to improve our services (GDPR Art. 6(1)(a)).'	Link to full Privacy Policy section 4.2 (Behavioral Biometrics)
Accept / Reject / Customize buttons	All three buttons equally prominent (no dark patterns). WCA 2.1.2: Acceptance must be affirmative; reject button must not be grey/hidden	WCA 2.1.2: Acceptance must be affirmative; reject button must not be grey/hidden
Confirmation screen	'Your choices have been saved. You can change these anytime in Settings or Privacy account settings at any time'	Reference to 'Settings' or 'Privacy' account settings

Consent Record Schema (PostgreSQL)

Table: user_consent_records — append-only (no updates, only inserts):

```
user_id UUID, consent_version VARCHAR(10), essential_consent BOOL DEFAULT TRUE, behavioral_consent BOOL, consent_timestamp TIMESTAMPTZ, ip_address_hash VARCHAR(64), user_agent_hash VARCHAR(64), withdrawal_timestamp TIMESTAMPTZ, withdrawal_method VARCHAR(50)
```

Consent version tracks the Privacy Policy version — if policy changes, re-consent is triggered. Withdrawal timestamp is set on opt-out; triggers the erasure workflow for behavioral data only.

G-09 · Data Retention Enforcement Automation

Stating a retention policy is meaningless without automation that enforces it. This defines the complete automated pipeline.

Data Store	Retention Rule	Automation Method	Schedule	Verification
Redis sessions	TTL-based (24h sliding)	Redis TTL — automatic	N/A — inherent	Prometheus: redis_expired_keys_total monitored
PostgreSQL login_history	90 days from login_time	pg_partman: auto-detach partition	Daily at 03:00 UTC	ClickHouse: row counts match with PostgreSQL
PostgreSQL risk_events	7 years (legal hold)	pg_partman: archive to S3 after 90 days	Monthly hard delete	DPA audit report: sample 100 records quarterly
ClickHouse analytics	2 years full resolution; 5 years aggregated (daily granular)	ClickHouse TTL (daily granular, 1 year)	Daily (ClickHouse TTL)	ClickHouse: 1 year to DPO dashboard
S3 training data (Parquet)	7 years (model lineage)	S3 Lifecycle Policy: Glacier after 1 year	Quarterly auto-transition	S3 Inventory report reviewed by DPO
Neo4j graph nodes	User nodes: erased on device removal; Penetration test findings: 2 years	Nightly Sys. Device Removal; Penetration test findings: 2 years	Daily (device removal), Monthly (findings)	Weekly associations by IP address dashboard
Audit logs (OpenSearch)	7 years (compliance)	ILM policy: hot→warm→cold→frozen	OpenSearch: 7 years ILM	Monthly ILM status report; alert if any deletion < 7 years

ML Gaps

G-10 · Model Bias & Fairness Audit

A fraud detection model trained on historical data can perpetuate or amplify systemic biases. If protected characteristics (directly or via proxy features) correlate with higher risk scores, the organization faces significant legal liability under EU AI Act (high-risk AI system classification), ECOA, and Fair Credit Reporting Act.

Protected Characteristics & Proxy Features

Protected Characteristic	Potential Proxy Features in Our System	Risk Level
Race / Ethnicity	IP geolocation → neighborhood → zip code → demographic composition; typing speed; language input	HIGH
National Origin	Country of IP geolocation; device language settings; keyboard layout	HIGH
Religion	None direct — low risk	LOW
Gender	Typing speed patterns (some research suggests gender differences); mouse movement style	Medium
Age	Typing speed; dwell time (older users type slower); device model (older hardware)	Medium
Disability	Typing cadence (users with motor disabilities have different patterns); use of accessibility tools	HIGH
Socioeconomic Status	Device model (low-end hardware may be more common in lower income groups); browser type (Chrome vs. others)	HIGH

Fairness Metrics — Mandatory Quarterly Audit

Metric	Definition	Target	Audit Frequency
Demographic Parity	Fraud flag rate should not differ > X% across demographic groups (applying geo-cluster)	≤ 5% disparity	Quarterly
Equal Opportunity	True Positive Rate (catching real fraud) should be equal across groups	± 0.01 TPR disparity	Quarterly
Calibration	Predicted fraud probability should match actual fraud rate within each group	± 0.02 calibration error	Quarterly
Individual Fairness	Similar users (same behavioral profile) should receive similar predictions regardless of protected attributes	≤ 0.1 difference in predicted risk	Continuous monitoring

Bias Mitigation Pipeline

- Pre-processing: Remove zip code as a direct feature; use regional fraud rate as a normalized contextual feature instead
- Pre-processing: Accessibility tool signatures (screen readers, alternative keyboards) added to WHITELIST_SIGNALS — zero risk penalty
- In-processing: Fairness constraints in XGBoost training using fairlearn adversarial debiasing
- Post-processing: Equalized odds post-processing calibrates decision thresholds per demographic cluster
- Monitoring: Fairness dashboard in Grafana — alerts if any metric breaches target; blocks model promotion
- Audit: Annual external algorithmic audit by certified third party; findings published in internal AI governance report
- Governance: AI Ethics Review Board (CISO + Legal + DPO + Product) must approve any new feature that could introduce bias

G-11 · Cold-Start Strategy for New Accounts

New users have no behavioral baseline, no device history, and no transaction history. The previous blueprint only mentioned '+10 points' which is insufficient. A structured cold-start protocol is required to minimize both fraud exposure and false positives during the baseline construction period (first 14 sessions).

Session #	Baseline Status	Risk Score Modification	Step-Up Threshold	Special Rules
1 (Registration)	Bootstrapping begins	+80 pts base penalty	Score > 300 triggers alert	New user registration encouraged (incentive: 'Secure your account')
2–3	Sparse baseline (< 20 events)	+50 pts	Score > 250	Geo velocity check extra sensitive; new country = +200 pts

Session #	Baseline Status	Risk Score Modifier	Step-Up Threshold	Special Rules
4–7	Partial baseline (20–100 events)	+40pts	Score > 350	Device fingerprint must match session 1 or trigger soft challenge
8–10	Growing baseline (100–300 events)	+20pts	Score > 450	First behavioral anomaly detection active
11–13	Near-mature baseline (300+ events)	+10pts	Score > 500	Standard RBA thresholds with cold-start modifier
14+ (Mature)	Full baseline established	No modifier	Standard threshold	EWMA updates begin; cold-start period ends; user notified

Population Baseline Bootstrap

For sessions 1–3 where individual baseline is insufficient, the system uses a population-level baseline segmented by: device_type × browser × geo_region. This provides a statistically meaningful comparison even with zero user history. Population baselines are updated weekly from the full user population.

G-12 · Adversarial Testing Framework

Fraud actors actively probe and adapt to detection systems. Without a structured adversarial testing program, the ML models will degrade as attackers learn to evade them.

Red Team Exercises — Quarterly

Attack Type	Technique	Test Frequency	Success Metric
Behavioral Mimicry	Train a generative model (GAN) on legitimate user behavior to synthesize realistic event sequences	Quarterly	Can the system detect synthetic behavior? (Score < 350)
Canvas Spoofing	Test latest anti-detect browsers (Multilogin, etc.) against the system's canvas fingerprinting model	Monthly	Can the system detect spoofed canvas fingerprints?
Credential Stuffing at Scale	Simulate 10,000 login attempts from rotating proxies with realistic timing	Monthly	Does the login check + IP reputation block > 99% within 5 minutes?
Account Warming	Create accounts, build legitimate-looking history over 30 days, then detect fraud	Quarterly	Can the system detect accounts that warm up and then go fraudulent within 3 sessions of behavior change?
Model Inversion	Attempt to reverse-engineer fraud score logic by querying the system with crafted inputs	Quarterly	Can the system detect attempts to reverse-engineer score components? (Differential privacy)
Feedback Loop Poisoning	Submit false confirmation data to model feedback endpoint	Quarterly	Does anomaly detection in feedback pipeline catch poisoning attempts?
Null Island Injection	Submit transactions with (0,0) coordinates or other invalid geo data	Monthly	Does the geo-validation reject 100% of Null Island variants?

Automated Adversarial CI Tests

- Textual adversarial inputs (for any NLP components): TextFooler + BERT-Attack libraries in CI
- Behavioral adversarial inputs: synthetic event sequences generated by LSTM trained on fraud patterns — must score > 600
- API rate limit bypass attempts: 47 known rate limit evasion techniques tested automatically on every release
- Auth bypass: OWASP Authentication Cheat Sheet test suite — 100% must pass

Operations Gaps

G-13 · Runbook Templates

Complete runbooks for the 6 highest-impact incident scenarios. Each runbook follows the format: Detection → Assessment → Mitigation → Recovery → Post-Mortem.

Runbook RB-001: Redis Cluster Node Failure

Step	Action	Command / Tool	Owner
1. DETECT	Alert fires: redis_cluster_nodes_total{cluster="prod"} > 10	Grafana PagerDuty P1	On-call SRE
2. ASSESS	Check which node failed and current cluster health	redis-cli -h <cluster-endpoint> cluster nodes grep fail	On-call SRE
3. VERIFY IMPACT	Check error rate in dashboard	Grafana dashboard: redis_error_rate{cluster="prod"}	On-call SRE
4. IMMEDIATE MITIGATION	Failover to replica	redis-cli -h <cluster-endpoint> failover	On-call SRE
5. IF NO AUTO-FAILOVER	Manual failover of the failed node	redis-cli -h <cluster-endpoint> cluster failover	On-call SRE
6. REPLACE NODE	Replace failed Redis node via Terraform	terraform apply target=module.redis.aws_elasticache_node.replacement	DevOps
7. REBALANCE	Rebalance slots across all 6 nodes	redis-cli -h <cluster-endpoint> cluster rebalance	DevOps
8. VERIFY	Firm all 6 nodes healthy, slot distribution	redis-cli -h <cluster-endpoint> cluster info	On-call SRE
9. POST-MORTEM	Incident review — root cause analysis template	Post-Mortem Template	On-call Commander

Runbook RB-002: ML Scoring Engine Down (Circuit Breaker Open)

Step	Action	Command / Tool	Owner
1. DETECT	Alert: circuit_breaker_state{service="ml-scoring"} == OPEN	PagerDuty P1	On-call SRE
2. VERIFY DEGRADED	Check if ML Scoring Engine is active	Grafana check: ml_scoring_engine_status	On-call SRE
3. CHECK LOGS	Check ML Scoring Engine pod logs	kubectl logs -n ml-scoring-engine	On-call SRE
4. CHECK GPU	Check GPU node health	kubectl exec -n ml-scoring-engine -- curl -s http://localhost:8080/health	On-call SRE
5. RESTORE	Restart pod (K8s will restart)	kubectl delete pod <pod-name> -l app=ml-scoring-engine	On-call SRE
6. VERIFY RECOVERY	Check if ML Scoring Engine is ready	kubectl exec -n ml-scoring-engine -- curl -s http://localhost:8080/health	On-call SRE
7. IF STILL DOWN	Escalate to ML Engineering	Alert: ml_scoring_engine_down	On-call SRE
8. NOTIFY	Post in #incidents Slack channel	Slack #incidents	On-call SRE

Runbook RB-003: False Positive Storm (Auto-Block Rate 3× Baseline)

Step	Action	Owner	Urgency
1. DETECT	Alert: auto_block_rate > 3× 7-day rolling average	PagerDuty P1	IMMEDIATE
2. ESTIMATE IMPACT	Calculate # of users blocked in last 30 minutes	Grafana check: auto_block_rate	On-call SRE
3. IDENTIFY CAUSE	Compare current score distribution vs. baseline	Grafana check: score_distribution	On-call SRE
4A. IF RULE CHANGE	Roll back last policy change via Policy Manager	Policy Manager	On-call SRE
4B. IF MODEL DRIFT	Force circuit breaker OPEN on ml-scoring-engine	ml-scoring-engine	On-call SRE
4C. IF DATA ISSUE	Check if Null Island spike or geo data	Clickhouse	On-call SRE
5. UNBLOCK USERS	Bulk session restore for confirmed false positives	Session Restore	On-call SRE
6. COMMUNICATE	Customer-facing status page update; Slack page	Status page	On-call SRE
7. POST-MORTEM	48h deadline — root cause, model/rule	Post-mortem	On-call SRE

Runbook RB-004: Kafka Consumer Lag > 10,000 Messages

- DETECT: Alert `kafka_consumer_lag{group='fraud-processor'} > 10000`
- ASSESS: Check Flink TaskManager health — is stream-processor running?
- SCALE: `kubectl scale deploy stream-processor --replicas=+2` (add Flink TaskManagers)
- CHECK PARTITION COUNT: If lag persists, Kafka partition count may need increase (requires topic recreation — planned operation)
- IF BACKPRESSURE: Identify slow downstream (feature-store lookup latency) — check Redis latency metrics
- RECOVERY SLA: Lag must return to < 1000 within 15 minutes of scaling action or escalate to ML Lead

Runbook RB-005: Database Primary Failure (PostgreSQL)

- DETECT: Alert: `postgres_replication_lag{role='primary'} IS NULL` (primary gone)
- AUTO-FAILOVER: Patroni (HA manager) promotes replica to primary within 30s — verify
- VERIFY: Check connection strings in application configs — Kong upstream must point to new primary
- DNS UPDATE: Patroni updates DNS automatically — confirm propagation within 60s
- RESTORE REPLICA: Provision new replica from S3 base backup + WAL replay; reattach to Patroni cluster
- POST-MORTEM: Was it hardware failure, OOM, or network partition? Root cause determines fix.

Runbook RB-006: Critical Security Alert (CRITICAL Risk Score Event Unclaimed > 5 min)

- DETECT: Alert: `alert_age_minutes{severity='CRITICAL'} > 5 AND status='UNCLAIMED'`
- AUTO-ESCALATE: PagerDuty escalates to Analyst Lead; Analyst Lead has 5 more minutes before CISO is paged
- INTERIM ACTION: System automatically elevates session to BLOCK state if unclaimed CRITICAL alert > 10 min
- ANALYST CLAIMS: Reviews session timeline, device fingerprint, behavioral heatmap in dashboard
- DECISION: Confirm Fraud → trigger account lock + SAR draft | Dismiss → log reasoning + flag for model review
- REVIEW: All CRITICAL alerts reviewed in weekly analyst calibration session for model improvement

G-14 · SLA Breach Escalation Matrix

SLA Metric	Green (Normal)	Yellow (Warning)	Red (Breach)	Yellow Action	Red Action	Escalation Path
API P99 Latency	< 80ms	80–150ms	≥ 150ms	Auto-alert on-call SRE via Slack	PagerDuty P1 — on-call SRE paged	SRE Lead (15m)
Risk Score Availability	100%	99.9–100%	< 99.9%	Slack alert + circuit breaker	PagerDuty P1 — fallback to SRE	SRE Activated → CISO
Session Manager Availability	100%	99.99–100%	< 99.99%	Slack alert	PagerDuty P1 — escalate to SRE	SRE Lead (5m)
Kafka Consumer Lag	< 1,000 msgs	1K–10K msgs	≥ 10K msgs	Scale Flink workers +2	PagerDuty P2 — investigate	SRE Data Pipeline Lead
Model Precision (weekly)	Baseline	Baseline–5%	< baseline–5%	Slack alert to ML team	Trigger emergency retraining	ML Lead → Head of ML
Auto-block rate	Baseline ±20%	Baseline ±20–100%	> 100% × baseline	Investigate signal spike	False positive protocol (AB-003)	SRE Lead → CISO
CRITICAL alert response	≤ 5 min	5–10 min	≥ 10 min	Escalate to Analyst Lead	CISO paged; session auto-kill	Analyst Lead → CISO
Erasure request completion	≤ 30 days	25–30 days	≥ 30 days	DPO reminder	DPO emergency protocol	DPO Legal Review → CEO

G-15 · Infrastructure Cost Estimation (AWS, USD/month)

Estimates based on AWS us-east-1 pricing, on-demand rates. Reserved instances (1-year) reduce compute costs by ~40%. Assumes 50M events/day ingestion, 5M users, 500K active sessions peak.

Component	AWS Service	Spec	Est. Monthly Cost (On-Demand)	Est. Monthly Cost (Reserved)
API Workers (3-10 nodes)	EC2 c6i.2xlarge	Avg 5 nodes × \$0.34/hr	\$1,224	\$734
Stream Processing (EKS)	EC2 c6i.4xlarge	4 nodes × \$0.68/hr	\$1,958	\$1,175
ML Inference (GPU)	EC2 g4dn.xlarge	2 nodes × \$0.526/hr	\$758	\$455
ML Training (on-demand)	EC2 p3.8xlarge	~40hr/month × \$12.24/hr	\$490	N/A (spot: ~\$175)
PostgreSQL + Citus	RDS r6i.4xlarge × 6	6 nodes × \$1.008/hr	\$4,356	\$2,614
Redis Cluster (6 nodes)	ElastiCache r6g.xlarge × 6	6 × \$0.239/hr	\$1,033	\$620
ClickHouse	EC2 c6i.4xlarge × 3	3 × \$0.68/hr	\$1,469	\$881
Neo4j Aura Enterprise	Neo4j managed	4 vCPU, 16GB	\$800	\$800 (contract)
Kafka (MSK)	Amazon MSK m5.xlarge	3 brokers + storage	\$1,200	\$720
S3 Storage (training logs)	S3 Standard + Glacier	~50TB total	\$1,200	\$1,200
Data Transfer	AWS egress	~10TB/month outbound	\$920	\$920
Kubernetes Control Plane	EKS	2 clusters (primary + DR)	\$146	\$146
Vault (HashiCorp Cloud)	AWS CloudP Vault Plus	Production cluster	\$600	\$600
Monitoring (Prometheus)	ECS/Grafana managed	2 nodes + Grafana Cloud	\$400	\$300
Kong Enterprise	Kong license	Per-node licensing	\$2,000	\$2,000 (annual contract)
TOTAL (approximate)			~\$18,554/month	~\$13,140/month

Cost optimization levers: Spot instances for ML training (save 70%); S3 Intelligent-Tiering for cold data; Savings Plans for baseline compute; VPC endpoints to reduce data transfer costs. Estimated cost at Reserved 1yr: ~\$13,140/month (~\$157,680/year).

Mobile SDK Design

G-16 · Mobile SDK — iOS & Android Full Specification

The mobile SDK captures behavioral and device signals natively, with higher fidelity than a web browser allows. SDK size budget: iOS < 500KB, Android < 400KB (AAR). SDK uses background threads exclusively — zero impact on main thread / UI.

iOS SDK (Swift Package)

Signal	API Used	Data Captured	Privacy Permission Required
Touch Behavior	UIGestureRecognizer / UIEvent	Tap pressure, touch radius, swipe velocity, gesture duration, touch coordinates (relative, normalized)	None — touch events always accessible
Typing Cadence	UITextFieldDelegate / UITextViewDelegate	Key timing (dwell/flight) via keyboard notifications — characters never logged	None
Device Accelerometer	CMMotionManager	Device orientation during interaction; grip motion & force (NSMotionUsageDescription)	Location & Fitness (NSMotionUsageDescription)
Device Gyroscope	CMMotionManager	Device tilt and rotation during form interaction	Same as above
Device Fingerprint	UIDevice + ProcessInfo	Model (UIDevice.model), iOS version, screen scale, total memory tier, CPU count	None
Screen Interaction	UIApplication event interception	Scroll velocity, tap interval, session navigation flow	None
Network Context	Network.framework (NWPathMonitor)	Connection type (WiFi/Cellular), is VPN active	None (no IP address)
App Attestation	DeviceCheck + App Attest API	Apple-signed attestation that app is genuine, not modified or jailbroken	None — verified via Apple key

Android SDK (Kotlin, AAR)

Signal	API Used	Data Captured	Privacy Permission Required
Touch Behavior	MotionEvent	Pressure, size, pointer coordinates (relative), time to first event	None — touch events always accessible
Typing Cadence	TextWatcher / KeyEvent	Key timing via system clock — characters never logged	None
Accelerometer / Gyroscope	SensorManager	Device motion during interaction — grip and orientation standard sensors, no permission	None
Device Fingerprint	Build class + ActivityManager	Manufacturer, model, Android version, screen density, total RAM tier, CPU ABI	None
Play Integrity API	Play Integrity	Google-signed verdict: MEETS_DEVICE_INTEGRITY / DOES_NOT_MEET_DEVICE_INTEGRITY / VERDICT_FAILED / VERDICT_STRONG_INTEGRITY — device attestation	None
Network Context	ConnectivityManager	Connection type, metered vs. unmetered, VPN access flag	ACCESS_NETWORK_STATE (normal permission)
Accessibility Service	AccessibilityManager	Is an accessibility service active? (bot overlay detection)	None — read-only check

SDK Integration Architecture

- SDK initializes on app launch (AppDelegate / Application.onCreate) with API key + user_id
- All data buffered in-memory; flushed to event-producer API every 30s or on significant user action
- Transmission uses Certificate Pinning (HPKP via TrustKit iOS / OkHttp CertificatePinner Android) — prevents MITM
- SDK self-disables if tampering detected (Play Integrity VERDICT_FAILED or App Attest failure)
- Opt-out: SDK checks consent_store on device — if behavioral_consent=false, only device fingerprint collected
- SDK version auto-updates via server-side config flag — no app store release required for SDK config changes
- Minimum OS: iOS 15+ (App Attest requires iOS 14+; Swift concurrency requires 15+); Android API 26+ (Android 8.0)

User Experience Gaps

G-17 · Dispute & False-Positive Resolution Workflow

When a legitimate user is blocked (false positive), their experience of the dispute process determines whether they remain a customer. The workflow must be fast, human-centered, and not reveal information useful to actual fraudsters.

User-Facing Dispute Entry Points

Scenario	Entry Point	Initial Message (UX Copy)	Dispute Path
SUSPICIOUS_BLOCK (700-899)	On block interstitial: 'This wasn't me'	We noticed something unusual. Let's make sure you're the real you.	Guided identity verification flow
AUTO_BLOCK (900-1000)	Support link on generic error page	Something went wrong. Our team can help.	Support ticket (no self-service — too high risk)
Unexplained step-up challenge	Why am I being asked this?	Please explain: 'We noticed this information looks a little different.'	Immediate dispute needed; just expand on what you know
Account recovery after lock	Email from noreply@ with recovery link	We'd like to get you verified for security. Here's how.	Guided recovery with strong identity verification

Guided Identity Verification Flow (Self-Service, for SUSPICIOUS_BLOCK only)

Step	User Action	System Action	Time Limit
1. Acknowledge	Click 'This wasn't me'	Create dispute ticket; send email to verified channels on file	15 minutes
2. Email verification	Click link in email	Verify link is fresh (15-min TTL); confirm email ownership	15 minutes
3. Identity questions	Answer: 'What was your first name?' OR 'What city did you register from?'	Verify against account data; OR verify against stored public key	2 minutes
4. WebAuthn (if available)	Use registered biometric or security key	Verify against stored public key	2 minutes
4b. SMS fallback (if no WebAuthn)	Enter TOTP	Verify TOTP; TOTP check	10 minutes
5. Confirmation screen	Screen: 'Your account is restored'	Clear block; create new session; flag device as 'dispute-verified'; reduce device risk modifier by -100 points	Immediate
6. Security setup	Optional: 'Want to make your account more secure?'	WebAuthn registration or 2FA setup	Optional

Support Ticket Flow (for AUTO_BLOCK — human review required)

- User submits support ticket via web form (account not required — anonymous form accessible)
- Ticket contains: email address, description, device type — NO account details requested in form (phishing risk)
- Support agent verifies identity via video call (Liveness check via Persona.com API) OR notarized document for high-value accounts
- Analyst reviews: session timeline, behavioral signals, device fingerprint — makes manual RESTORE decision
- Restoration: support agent triggers admin API POST /v1/admin/restore/{user_id} with ticket_id + analyst_id
- SLA: SUSPICIOUS_BLOCK self-service restored within 30 minutes; AUTO_BLOCK human review within 4 business hours
- Post-resolution: feedback tag CONFIRMED_LEGITIMATE_USER applied to session data — feeds model improvement

Anti-Fraud Protections in Dispute Flow

- Dispute form rate-limited: max 3 dispute attempts per IP per 24h
- Email verification is mandatory — no dispute without access to registered email
- Each dispute attempt logged and analyzed — multiple dispute attempts from same device = elevated fraud signal
- Social engineering protection: support agents trained to never restore accounts based on phone calls alone
- Fraudster-aware: AUTO_BLOCK dispute requires human review precisely because fraudsters know self-service flows

Architecture Gap: Multi-Tenancy Isolation Model

G-18 · Multi-Tenancy Isolation Model

If AntiGravity serves multiple enterprise clients (tenants), strict data isolation is non-negotiable. A breach of one tenant's data into another tenant's view is a critical security and contractual failure. Three isolation models exist — this section defines the chosen model and its complete implementation.

Isolation Model Comparison

Model	Description	Data Isolation	Cost	Chosen For
Silo (Full Isolation)	One K8s cluster + one database per tenant	Complete — no shared infrastructure	High (\$100K+/tenant)	Enterprise clients with contractual data residency requirements
Pool (Full Shared)	Single shared infrastructure; tenant_id in every table	Not possible — applications share everything	Low (\$5K+/tenant)	Small SaaS providers (< \$10K ARR)
Bridge (Hybrid)	Shared compute, isolated database schemas	Strong separation; tenant_id in every table	Medium (\$20K+/tenant)	PRIMARY MODEL for mid-market tenants

Bridge Model — Technical Implementation

Layer	Isolation Mechanism	Implementation
API Gateway	Tenant identification via subdomain	tenant_id is a required header; validate it against the tenant registry before routing to services
Application Services	All services receive tenant_id in request context	Context propagation: extract tenant_id from request headers and inject it into all downstream calls
Kafka Topics	Tenant-scoped topics: ag.events.raw	Kafka ACLs: each tenant's schema registry entry is isolated; each tenant's producer/consumer must use its own topics
PostgreSQL (Citux)	Row-Level Security (RLS) on ALL tables	CREATE ROLE tenant_id; GRANT ALL PRIVILEGES ON tenant_id schema TO tenant_id; RLS policies enforce isolation
Redis (Sessions)	All session keys prefixed: {tenant_id}:	Redis ACLs: each tenant's session keys are isolated; Redis keys are prefixed with its tenant_id
ClickHouse	tenant_id is a shard key and mandatory filter	Query templates use tenant_id as a mandatory filter; all queries must include tenant_id in the WHERE clause
Neo4j	Separate graph database per tenant	Neo4j database instances are isolated by tenant_id; all queries must specify the tenant_id database
ML Models	Shared base model + tenant-specific fine-tunes	MLflow separate (local registry) namespace per tenant; all model artifacts are tagged with tenant_id
Audit Logs	Audit log includes tenant_id; each tenant has its own audit log	Optimistic security: all audit logs are tenant-scoped; all database queries are logged with tenant_id

Tenant Onboarding Automation

- New tenant provisioned via Terraform module: creates Kafka ACLs, Redis ACL, PostgreSQL tenant schema, Neo4j database, K8s namespace + RBAC, API key
- Provisioning time: < 5 minutes fully automated via GitOps pipeline
- Tenant configuration stored in tenant registry service (PostgreSQL + Redis cache) — consulted by all services at startup
- Offboarding: full data deletion workflow per tenant — same mechanism as GDPR erasure but tenant-scoped
- Isolation validation: automated test suite runs after each tenant creation — cross-tenant data access attempt must fail with 403

Silo Model (Enterprise — Full Isolation)

- Dedicated EKS cluster per tenant (provisioned via Terraform + ArgoCD GitOps)
- Dedicated RDS instance + ElastiCache cluster per tenant — no shared database infrastructure
- Dedicated VPC with private peering to AntiGravity management plane only
- Custom domain: fraud-api.client-name.com (tenant manages DNS; AntiGravity provides cert via ACM)
- Dedicated MLflow workspace and model registry — tenant models never co-mingle
- Pricing: Silo model for tenants > \$100K ARR or those with contractual data residency SLAs

All 16 gaps identified in the initial review have been fully resolved in this supplement. This document should be maintained alongside the primary blueprint and updated whenever new gaps are identified through incident review, security audit, or regulatory change.

AntiGravity AI Systems · Gaps & Oversights Supplement · Confidential · March 2026 · v1.0